

INTERNAL — CONFIDENTIAL

PaySafe India

INTERNAL AUDIT REPORT

ISO/IEC 27001:2022 Information Security Management System

Follow-Up Audit of Remediation Effectiveness — Access Control, Logging & Monitoring, and Third-Party Security

Document Title	PaySafe India — Internal Audit Report: ISMS Control Effectiveness (Follow-Up Audit)
Audit Reference	PSI-IA-2026-04
Subject Organization	PaySafe India (Digital Payments, UPI, BNPL Lending & Card Processing)
Audit Period (Fieldwork)	16 June 2026 — 10 July 2026
Report Issue Date	15 July 2026
Document Classification	Internal — Confidential
Version	v1.0 — Final
Lead Internal Auditor	[Ayush Joshi] — Internal Audit & GRC Function
Report Recipients	Chief Information Security Officer (CISO); Audit Committee; Head of Compliance
Related Prior Deliverables	Risk Register (v1.0); ISO 27001:2022 Gap Analysis (v1.0); Access Control Policy (v1.0)

Table of Contents

Table of Contents.....	1
1. Executive Summary	2
1.1 Audit Opinion Summary	2
1.2 Basis for Overall Audit Opinion.....	3
2. Scope and Methodology.....	4
2.1 In-Scope Controls.....	4
2.1.1 Carried Forward from the ISO 27001:2022 Gap Analysis (12 controls).....	4
2.1.2 Additional High-Risk Controls (5 controls, selected by Risk Register score).....	4
2.2 Out of Scope	4
2.3 Testing Methodology.....	5
2.3.1 Sample Sizing Rationale	5
2.3.2 Evidence Types by Control Type	6
2.4 Relationship to Prior Deliverables	6
2.5 Audit Limitations.....	6
3. Findings.....	7
4. Appendices	13
Appendix A — Evidence Planning Matrix	13
Appendix A.1 — Detailed Test Procedures.....	15
Appendix B — List of Documents Reviewed.....	17
Appendix C — Auditee List	18
Appendix D — Risk-Based Control Prioritization Rationale.....	19
5. Remediation Tracking Table	20

1. Executive Summary

Internal Audit conducted a follow-up audit of PaySafe India's Information Security Management System (ISMS) between 16 June 2026 and 10 July 2026, covering the 12 Annex A controls previously rated Red or Amber in the ISO/IEC 27001:2022 Gap Analysis (v1.0) together with five additional high-risk controls selected on the basis of Risk Register (v1.0) scoring. The objective was twofold: to determine whether the remediation actions committed against the 12 previously non-compliant controls have been implemented and are operating effectively, and to determine whether controls not previously flagged continue to operate as designed. Based on the evidence obtained, Internal Audit's overall opinion is that the control environment is Partially Effective. Of the 12 previously flagged controls, 2 have been fully remediated and are now operating effectively, 6 remain non-compliant or have been only partially remediated, and 4 were superseded by newly-scoped testing that identified residual weaknesses of comparable severity. Of the five additional high-risk controls tested, one control — configuration management over production infrastructure — was found to have a material gap. In aggregate, this audit raises seven findings, of which two are rated Critical, two High, two Medium, and one Low.

The headline finding is that multi-factor authentication (MFA) is not consistently enforced for privileged and third-party vendor remote access into production payment-processing environments (Finding 01), and that the joiner-mover-leaver deprovisioning control mandated by the Access Control Policy (v1.0) continues to permit terminated personnel to retain active directory access beyond the 24-hour SLA (Finding 02). Both findings relate directly to Annex A controls rated Red in the prior Gap Analysis and indicate that remediation, while initiated, has not been completed or has not been operating consistently across the full population of privileged accounts. Internal Audit's top recommendation is that the CISO commission an emergency remediation sprint, sponsored at Head of IT Security level, to (a) enforce MFA universally for all privileged and third-party remote access paths into production UPI, BNPL, and card-processing systems, and (b) automate the deprovisioning workflow so that access revocation is triggered directly by the HR separation event rather than by manual IT Service Management (ITSM) ticket handling, closing both Critical findings within 30 days of report issuance. Management responses and target remediation dates for all seven findings are recorded in Section 7 (Remediation Tracking Table).

1.1 Audit Opinion Summary

Metric	Result
Overall Audit Opinion	Partially Effective
Controls in Scope	17 (12 carried forward from Gap Analysis + 5 additional high-risk controls)
Controls Fully Remediated / Operating Effectively	2 of 12 (17%)
Controls Not Remediated or Partially Remediated	6 of 12 (50%)
Controls Re-Scoped Under New Findings	4 of 12 (33%)
Additional High-Risk Controls with New Findings	1 of 5
Total Findings Raised	7 (2 Critical, 2 High, 2 Medium, 1 Low)

1.2 Basis for Overall Audit Opinion

Internal Audit's opinion-scoring methodology applies a threshold rule under which the presence of any Critical-rated finding caps the overall control-environment opinion at Partially Effective, irrespective of the proportion of previously-flagged controls that have since been fully remediated. This audit raised two Critical findings (Findings 01 and 02), both bearing directly on access to production payment-processing environments. Under this threshold rule, a single Critical finding is sufficient to preclude an opinion of Effective, regardless of the underlying remediation rate; an Effective opinion is reserved for control populations with zero Critical or High findings and, at most, isolated Medium/Low exceptions already under remediation. This is why the overall opinion remains Partially Effective even though 2 of the 12 previously-flagged controls (17%) have been fully remediated: the remediation rate describes the breadth of progress since the Gap Analysis, but it is the severity of the two open Critical findings — not the proportion of controls closed — that determines the ceiling on the overall opinion.

2. Scope and Methodology

2.1 In-Scope Controls

This audit is scoped to test the operating effectiveness of 17 Annex A controls: (i) the 12 controls rated Red or Amber in the ISO/IEC 27001:2022 Gap Analysis (v1.0), specifically within the access control, logging and monitoring, and third-party security domains; and (ii) five additional controls selected because the assets or processes they protect carry the highest Likelihood × Impact scores in the Risk Register (v1.0). The full control list, mapped to risk score and testing depth, is presented in Section 3 and reproduced in full at Appendix A.

2.1.1 Carried Forward from the ISO 27001:2022 Gap Analysis (12 controls)

- A.5.15 Access Control; A.5.18 Access Rights (user access review and deprovisioning).
- A.8.5 Secure Authentication (multi-factor authentication enforcement).
- A.8.2 Privileged Access Rights (Privileged Access Management).
- A.8.15 Logging; A.8.16 Monitoring Activities.
- A.5.19 Information Security in Supplier Relationships; A.5.20 Addressing Information Security Within Supplier Agreements; A.5.22 Monitoring, Review and Change Management of Supplier Services.
- A.8.9 Configuration Management.
- A.8.24 Use of Cryptography.
- A.6.3 Information Security Awareness, Education and Training.

2.1.2 Additional High-Risk Controls (5 controls, selected by Risk Register score)

- A.8.1 User Endpoint Devices.
- A.8.3 Information Access Restriction.
- A.5.30 ICT Readiness for Business Continuity.
- A.8.28 Secure Coding.
- A.8.23 Web Filtering.

2.2 Out of Scope

The following are explicitly out of scope for this audit and were not tested:

- Physical and environmental security controls (Annex A.7 series), which were rated Green in the prior Gap Analysis and carry a Risk Register score below the inquiry-only threshold.
- Controls governing PaySafe India's internal HR systems that do not process cardholder data, customer PII, or transaction data.
- PCI DSS attestation testing in its own right; PCI-relevant observations are noted only where they overlap with an in-scope ISO 27001 Annex A control (e.g., cryptography, access restriction).
- RBI regulatory return filings and DPDP Act 2023 breach-notification process testing, which are covered under a separate compliance-function review scheduled for Q4 2026.

- Controls at newly onboarded vendors contracted after 30 June 2026, which fall outside the audit period.

2.3 Testing Methodology

For each in-scope control, Internal Audit defined a control population, selected a sample using a risk-graded sampling approach, and executed a test procedure appropriate to the nature of the control. Testing depth was assigned according to the risk score of the underlying asset or process from the Risk Register, using the following tiers, consistent with the tiering used in the Evidence Planning Matrix:

Risk Score	Testing Depth	Approach
15 – 25	Full Testing	Full population walkthrough where the population is small, or a statistically-derived sample at 90% confidence with zero tolerable deviation for larger populations; corroborated with re-performance or observation.
8 – 14	Targeted Sampling	A judgmental sample of 5 items weighted toward the highest-risk instances within the population (e.g., highest-privilege devices, most business-critical repositories).
1 – 7	Inquiry Only	Interviews with control owners and review of supporting management dashboards; no independent re-performance.

2.3.1 Sample Sizing Rationale

Sample sizes for Full Testing controls follow an attribute-sampling approach appropriate for tests of controls: a 90% confidence level, 0% expected deviation rate, and a 10% tolerable deviation rate. Applying the standard attribute-sampling formula ($n = \ln(1 - \text{confidence level}) \div \ln(1 - \text{tolerable deviation rate})$), with a finite-population correction applied for populations under 1,000 items) to the specific populations tested in this audit produces the following sample sizes:

Control Population (N)	Applicable Control(s)	Statistically-Derived Sample Size	Sample Size Applied
22 keys	A.8.24	11	8
42 accounts	A.8.5	15	8
60 hosts	A.8.9	16	12
240 alerts	A.8.16	20	15
612 accounts	A.8.2	21	20

Where fewer than 10 items existed in the population (e.g., in-scope logging systems, data stores), the full population was tested rather than a sample, consistent with Section 2.3. Where the sample actually tested falls below the statistically-derived figure (A.8.24, A.8.5, A.8.9, A.8.16), this reflects a risk-based judgmental reduction to fit fieldwork time constraints, corroborated by full document/configuration review rather than sample testing alone; this variance and its rationale should be documented in the working papers for each affected control.

2.3.2 Evidence Types by Control Type

- Document review: policies, procedures, configuration exports, contracts, tickets, and log extracts provided by the control owner.
- Observation: direct observation of a control operating (e.g., live authentication attempt, screen-share walkthrough of a configuration console).
- Re-performance: independent re-execution of a control activity by the audit team (e.g., re-running an access certification reconciliation, re-tracing a deprovisioning ticket against the HR separation date).
- Inquiry: structured interview of control owners, corroborated with at least one other evidence type where the risk score warrants it.

2.4 Relationship to Prior Deliverables

This report should be read alongside the Risk Register (v1.0), the ISO/IEC 27001:2022 Gap Analysis (v1.0), and the Access Control Policy (v1.0). The Gap Analysis assessed design and implementation status against the standard at a fixed point in time and produced RAG ratings; this audit does not repeat that exercise. Instead, it tests whether the controls rated Red or Amber in the Gap Analysis have since been remediated and are operating effectively in practice, and whether controls rated Green continue to operate as intended, using evidence obtained through sampling and testing rather than status attestation alone. Where a finding in this report relates to a control previously rated Red or Amber, the finding condition explicitly states whether the control has been fully remediated, partially remediated, or not remediated since the Gap Analysis.

2.5 Audit Limitations

This audit was performed using selective, risk-based sampling rather than 100% population testing for all but the smallest control populations, and relies on evidence and representations provided by control owners during the fieldwork period (16 June 2026 – 10 July 2026). Accordingly, it provides reasonable, but not absolute, assurance that the in-scope controls are operating effectively; exceptions may exist within the unsampled portion of any population that were not identified through this testing. Conclusions reflect each control's state as observed during fieldwork only; a control assessed as effective at the time of testing may subsequently degrade due to changes in personnel, technology, or process, and this report provides no assurance over the period following the fieldwork end date. Where testing relied on inquiry alone (Inquiry Only controls, e.g., A.6.3), findings are corroborated by at least one supporting document or dashboard but do not include independent re-performance, and therefore carry a lower level of assurance than Full Testing or Targeted Sampling controls.

3. Findings

This audit raises seven findings, presented in descending order of severity. Each finding follows the Condition / Criteria / Cause / Effect format and includes a recommendation, remediation owner, and target remediation date. A consolidated Remediation Tracking Table is provided at Section 7.

FINDING 01 [CRITICAL]

Multi-Factor Authentication Not Consistently Enforced for Privileged and Third-Party Remote Access

Control Reference: A.8.5 — Secure Authentication | **Status vs. Gap Analysis:** *Previously rated Red (Gap Analysis) — Partially Remediated*

Condition	Observation and re-performance testing was conducted against a sample of 8 privileged/administrator accounts drawn from a population of 42 accounts with remote access to production UPI switch, card-processing, and core-banking-interface environments. Of the 8 accounts tested, 5 were confirmed to require MFA at both the VPN and application layer, consistent with remediation work completed since the Gap Analysis. However, 3 of the 8 sampled accounts — all belonging to the third-party payment gateway vendor's support personnel — were found to authenticate to the production VPN using a static password only, with no second factor challenge, contrary to the requirement in the Access Control Policy (v1.0) that MFA be mandatory for all privileged and vendor remote access without exception.
Criteria	ISO/IEC 27001:2022 Annex A, Control A.8.5 (Secure Authentication) requires that secure authentication technologies and procedures be implemented based on information access restrictions and the topic-specific policy on access control, including the use of multi-factor authentication for access to systems that are critical or that process sensitive information.
Cause	Process Failure — the MFA enrolment step was completed for internally-managed privileged accounts as part of the remediation plan following the Gap Analysis, but the corresponding step was not extended to third-party vendor support accounts because vendor account provisioning follows a separate, undocumented onboarding path outside the standard Identity and Access Management (IAM) workflow.
Effect	Likelihood 4 (Likely) × Impact 5 (Severe) = 20 — Critical band on the Risk Register 5×5 scale, consistent with the "Admin Access" asset risk score of 20 recorded in the Risk Register (v1.0). A compromised vendor support credential would provide direct, unmonitored administrative access into production payment-processing infrastructure, creating exposure to unauthorized transaction manipulation, data exfiltration of customer PII, and a reportable incident under RBI and DPDP Act 2023 obligations.

Recommendation: Extend the existing MFA enforcement control to cover all third-party vendor remote-access accounts without exception, by routing vendor account provisioning through the same IAM workflow used for

internal privileged accounts. Conduct an immediate review of all currently active vendor remote-access sessions and suspend any account that cannot be brought into MFA compliance within 5 business days.

Remediation Owner: Head of IT Security **Target Remediation Date:** 15 August 2026

FINDING 02 [CRITICAL]

Terminated Employee Access Not Deprovisioned Within Required SLA

Control Reference: A.5.18 — Access Rights (user access review and deprovisioning) | **Status vs. Gap Analysis:** Previously rated Red (Gap Analysis) — Not Remediated

Condition	A sample of 5 employee separations was selected from a population of 18 separations processed during the audit period and traced from the HR-recorded last working day to the corresponding IT deprovisioning ticket closure timestamp. In 1 of the 5 samples, the terminated employee's Active Directory account, VPN access, and access to the BNPL loan-origination system remained active for 5 calendar days after the recorded exit date, against the 24-hour deprovisioning SLA defined in the Access Control Policy (v1.0). Ticket evidence indicates the deprovisioning request was logged by HR on the exit date but was not actioned by IT Operations until a follow-up escalation five days later.
Criteria	ISO/IEC 27001:2022 Annex A, Control A.5.18 (Access Rights) requires that the process for provisioning and revoking access rights to information and other associated assets be implemented in accordance with the organization's topic-specific policy on, and rules for, access control — including timely revocation of access upon termination of employment or contract.
Cause	Process Failure — deprovisioning is currently a manual, ticket-based handoff between HR and IT Operations with no system-enforced SLA escalation; the HR-to-IT handoff has no automated trigger tied to the HR information system's recorded separation date.
Effect	Likelihood 4 (Likely) × Impact 5 (Severe) = 20 — Critical band, consistent with the "Admin Access" asset risk score of 20 in the Risk Register (v1.0). Retained access by a departed employee, particularly to the loan-origination system, creates direct exposure to unauthorized data access, fraudulent transaction initiation, and a control failure that would be reportable to an external ISO 27001 certification auditor as a major nonconformity.

Recommendation: Automate the deprovisioning trigger so that account suspension is initiated directly and immediately from the HR information system's separation event, rather than relying on manual ticket creation and follow-up. Implement a system-enforced escalation that alerts the Head of IT Security if any deprovisioning ticket remains open beyond 12 hours.

Remediation Owner: IT Operations Manager **Target Remediation Date:** 31 August 2026

FINDING 03 [HIGH]**High and Critical Severity SIEM Alerts Not Triage Within Defined SLA**

Control Reference: A.8.16 — Monitoring Activities | **Status vs. Gap Analysis:** *Previously rated Amber (Gap Analysis) — Not Remediated*

Condition	A sample of 15 High and Critical severity alerts was selected from a population of 240 such alerts generated by the SIEM platform during the audit period and traced from alert generation to analyst triage. Of the 15 sampled alerts, 6 (40%) were triaged more than 4 hours after generation against the documented 1-hour SLA for High/Critical alerts, and 2 of those 6 showed no triage action recorded for over 24 hours. Interviews with the Security Operations team attributed the backlog to a single analyst covering monitoring duties outside standard business hours.
Criteria	ISO/IEC 27001:2022 Annex A, Control A.8.16 (Monitoring Activities) requires that networks, systems, and applications be monitored for anomalous behaviour and that appropriate actions be taken to evaluate potential information security incidents, within a defined and consistently-applied response timeframe.
Cause	Resource Constraint — the Security Operations function does not currently have 24x7 analyst coverage; a single analyst is responsible for after-hours triage across all monitored systems.
Effect	Likelihood 3 (Possible) × Impact 5 (Severe) = 15 — Critical/High band, consistent with the "Transaction Database" asset risk score of 15 in the Risk Register (v1.0). Delayed triage of Critical alerts extends attacker dwell time in production payment-processing systems and increases the likelihood that a genuine security incident is not detected or escalated within a timeframe sufficient to contain impact.

Recommendation: Establish 24x7 Security Operations coverage, either through additional headcount or a managed detection and response (MDR) service, and implement automated escalation paging for any Critical severity alert untriaged after 30 minutes.

Remediation Owner: Head of IT Security | **Target Remediation Date:** 30 September 2026

FINDING 04 [HIGH]**Third-Party Lending Data Partner Contract Lacks a Signed Information Security Addendum**

Control Reference: A.5.20 — Addressing Information Security Within Supplier Agreements | **Status vs. Gap Analysis:** *Previously rated Amber (Gap Analysis) — Not Remediated*

Condition	A sample of 5 vendor contracts was reviewed from the population of 14 active third-party vendors with system or data access, selected to prioritize the highest-risk relationships identified in the Risk Register. The contract governing PaySafe India's integration with its external credit-bureau data partner for BNPL underwriting decisions was found to contain standard commercial and data-sharing clauses but no dedicated information security addendum — specifically, it does not specify breach-notification timelines, right-to-audit provisions, or sub-processor flow-down security requirements. The remaining 4 sampled vendor contracts, including the card network acquirer and cloud IaaS provider, were confirmed to contain an appropriately executed security addendum.
Criteria	ISO/IEC 27001:2022 Annex A, Control A.5.20 (Addressing Information Security Within Supplier Agreements) requires that relevant information security requirements be established and agreed with each supplier based on the type of supplier relationship, and documented within the supplier agreement.
Cause	Process Failure — the current vendor onboarding checklist requires a security addendum for vendors classified as "system access" vendors, but the credit-bureau integration was classified at onboarding as a "data exchange" vendor, a category that was not mapped to the same contractual control requirement.
Effect	Likelihood 3 (Possible) × Impact 4 (Major) = 12 — High band, consistent with the "Third-Party Integrations" asset risk score of 16 in the Risk Register (v1.0). In the absence of a contractually binding breach-notification timeline, PaySafe India's ability to meet its own DPDP Act 2023 breach-notification obligations in the event of an incident originating at the credit-bureau partner is impaired.

Recommendation: Execute a security addendum with the credit-bureau partner within the current renewal cycle, and correct the vendor classification taxonomy so that any vendor receiving customer PII, regardless of the "data exchange" versus "system access" label, is mapped to the security addendum requirement.

Remediation Owner: Head of Compliance / Third-Party Risk Manager **Target Remediation Date:** 15 September 2026

FINDING 05 [MEDIUM]

Encryption Key Rotation Overdue for Customer PII Data-at-Rest

Control Reference: A.8.24 — Use of Cryptography | **Status vs. Gap Analysis:** *Previously rated Amber (Gap Analysis) — Partially Remediated*

Condition	A sample of 8 cryptographic keys was tested from a population of 22 keys protecting customer PII and payment data at rest and in transit. Key Management System (KMS) audit logs showed that 2 of the 8 sampled keys, both protecting customer PII database volumes, had not been rotated in over 14 months,
------------------	--

	exceeding the 12-month maximum rotation interval defined in the organization's Key Management Policy. The remaining 6 sampled keys, including all keys protecting card data, were rotated within policy.
Criteria	ISO/IEC 27001:2022 Annex A, Control A.8.24 (Use of Cryptography) requires that rules for the effective use of cryptography, including cryptographic key management, be defined and implemented in accordance with the organization's topic-specific policy on cryptography.
Cause	System Limitation — automated key rotation is enabled for the card-data encryption service but had not been extended to the customer-PII database encryption service, which still relies on a manual rotation runbook that was not executed on schedule.
Effect	Likelihood 2 (Unlikely) × Impact 4 (Major) = 8 — Medium band. While the encryption itself remains cryptographically sound, an overdue rotation extends the exposure window should a key ever be compromised, and represents a control gap against the Risk Register's "Customer PII Stores" asset, scored 25.

Recommendation: Extend automated key rotation coverage to the customer-PII database encryption service and decommission the manual rotation runbook once automated rotation is confirmed operating for at least one full cycle.

Remediation Owner: Head of Engineering (Infrastructure) **Target Remediation Date:** 31 October 2026

FINDING 06 [MEDIUM]

Security Awareness Training Completion and Phishing Resilience Below Target

Control Reference: A.6.3 — Information Security Awareness, Education and Training | **Status vs. Gap Analysis:** Previously rated Amber (Gap Analysis) — Remediated in Design; New Operating Observation

Condition	Inquiry was conducted with the HR Business Partner and IT Security Manager, corroborated by review of the training-completion dashboard and the most recent quarterly phishing-simulation report. Mandatory annual security-awareness training showed an 81% completion rate against a 95% target, and the most recent phishing simulation recorded an 18% click-through rate against a 10% target. The training program itself was confirmed to be in place and content was assessed as adequate; the gap identified relates to completion and behavioural outcomes rather than program design.
Criteria	ISO/IEC 27001:2022 Annex A, Control A.6.3 (Information Security Awareness, Education and Training) requires that personnel receive appropriate awareness education and training, and regular updates on

	the organization's information security policy, topic-specific policies, and procedures, relevant for their job function.
Cause	Awareness Gap — training completion is not currently tied to a manager-level performance metric or system access restriction, so there is limited organizational pressure to complete training by the assigned deadline.
Effect	Likelihood 3 (Possible) × Impact 3 (Moderate) = 9 — Medium band. An elevated phishing click-through rate increases the likelihood that a credential-harvesting or malware-delivery campaign against PaySafe India personnel succeeds, providing an initial access vector into the corporate environment.

Recommendation: Introduce a system-level restriction that suspends non-essential system access for personnel who have not completed mandatory training within 30 days of assignment, and report completion and phishing-simulation metrics to department heads on a monthly basis.

Remediation Owner: HR Business Partner / IT Security Manager **Target Remediation Date:** 30 September 2026

FINDING 07 [LOW]

Configuration Baseline Drift on Production Payment-Processing Hosts

Control Reference: A.8.9 — Configuration Management | **Status vs. Gap Analysis:** *Additional high-risk control (newly tested; not previously scoped in Gap Analysis)*

Condition	A sample of 12 hosts was tested from a population of 60 production servers/VMs supporting payment-processing workloads, comparing live configuration state against the approved CIS-based baseline. 2 of the 12 sampled hosts had deviated from baseline — one with an unauthorized open management port and one with a disabled host-based firewall rule — and neither deviation had an associated change-control record.
Criteria	ISO/IEC 27001:2022 Annex A, Control A.8.9 (Configuration Management) requires that configurations, including security configurations, of hardware, software, services, and networks be established, documented, implemented, monitored, and reviewed.
Cause	Process Failure — configuration drift detection currently runs on a weekly scheduled scan rather than continuously, and detected deviations are logged to a report that is not consistently reviewed against open change-control records.

Effect	Likelihood 2 (Unlikely) × Impact 2 (Minor) = 4 — Low band, though the affected asset class maps to the "Payment Processing Systems" risk in the Risk Register (scored 20), meaning any escalation in the frequency or severity of drift would warrant re-assessment at a higher risk tier.
---------------	--

Recommendation: Move configuration drift detection from weekly scheduled scanning to continuous monitoring, and require every detected deviation to be reconciled against an open change-control ticket within 48 hours or automatically reverted.

Remediation Owner: DevOps Lead **Target Remediation Date:** 31 October 2026

4. Appendices

Appendix A — Evidence Planning Matrix

The following matrix records, for each of the 17 in-scope controls, the Risk Register score used to set testing depth, the defined control population, the sample tested, and the evidence type obtained. Detailed test procedures for each control are provided in Appendix A.1.

Control ID	Control Name	Risk Score	Testing Depth	Population	Sample Size	Evidence Type	Ref.
A.5.15	Access Control	20	Full	All logical access provisioning records, PaySafe core banking gateway & UPI switch (6-month period)	10 records	Document review; re-performance	1
A.5.18	Access Rights	20	Full	Employee separation events processed in audit period (18 separations)	5 separations	Document review; re-performance	2
A.8.5	Secure Authentication	20	Full	Privileged/administrator accounts with remote access to production environments (42 accounts)	8 accounts	Observation; re-performance	3
A.8.2	Privileged Access Rights (PAM)	20	Full	Privileged/administrator user accounts across production UPI, BNPL, and card-processing applications (612 accounts)	20 accounts (statistical, 90% confidence)	Document review; re-performance	4
A.8.15	Logging	15	Full	In-scope production systems required to generate security logs (UPI switch, card-processing gateway, core banking interface, IAM, SIEM ingestion points — 9 systems)	9 systems (full population)	Observation; document review	5

Control ID	Control Name	Risk Score	Testing Depth	Population	Sample Size	Evidence Type	Ref.
A.8.16	Monitoring Activities	15	Full	High/Critical severity SIEM alerts generated in audit period (240 alerts)	15 alerts	Document review; re-performance	6
A.5.19	Information Security in Supplier Relationships	16	Full	Active third-party vendors with access to systems or data (14 vendors)	5 vendors (highest-risk: BNPL credit bureau, card network acquirer, cloud IaaS provider, KYC verification vendor, OTP/SMS gateway)	Document review; inquiry	7
A.5.20	Addressing Information Security Within Supplier Agreements	16	Full	Same vendor population as A.5.19 (14 vendors)	5 vendors (same sample as A.5.19)	Document review	8
A.5.22	Monitoring, Review and Change Management of Supplier Services	16	Full	Same vendor population as A.5.19 (14 vendors)	5 vendors (same sample as A.5.19)	Document review; inquiry	9
A.8.9	Configuration Management	20	Full	Production servers/VMs supporting payment-processing workloads (60 hosts)	12 hosts	Observation; re-performance	10
A.8.24	Use of Cryptography	25	Full	Cryptographic keys protecting data at rest and in transit for customer PII and payment data (22 keys)	8 keys	Document review; observation	11
A.6.3	Information Security Awareness, Education and Training	6	Inquiry only	All employees and contractors with system access (approx. 340 personnel)	N/A — interview + dashboard review (4 personnel interviewed)	Inquiry; document review	12
A.8.1	User Endpoint Devices	10	Targeted	Corporate-issued endpoint devices with access to production support tools (85 devices)	5 devices	Observation	13
A.8.3	Information Access Restriction	18	Full	Customer PII and payment-data stores/schemas (9 data stores)	6 data stores	Observation; re-performance	14
A.5.30	ICT Readiness for Business Continuity	12	Targeted	Documented ICT continuity/DR plans (1 consolidated plan set covering UPI switch, core	Full plan review + 1 walkthrough test	Document review; observation	15

Control ID	Control Name	Risk Score	Testing Depth	Population	Sample Size	Evidence Type	Ref.
				banking interface, and card-processing gateway)			
A.8.28	Secure Coding	14	Targeted	Production application code repositories for BNPL and card-processing services (18 repositories)	5 repositories	Document review; re-performance	16
A.8.23	Web Filtering	9	Targeted	Web/URL filtering policy configuration (1 rule set) and associated proxy logs	Full config review + 5-day log sample	Observation; document review	17

Appendix A.1 — Detailed Test Procedures

Control ID	Test Procedure
A.5.15	Trace a sample of access grants to an approved access request and role mapping in the RBAC matrix; confirm segregation of duties.
A.5.18	Trace HR separation date to IT deprovisioning ticket timestamp; confirm access revoked within 24-hour SLA per Access Control Policy.
A.8.5	Observe live authentication attempt for sampled accounts; confirm MFA challenge is enforced at VPN and application layer.
A.8.2	Re-perform the quarterly access certification for a sample of accounts; confirm reviewer sign-off and evidence of revocation for flagged accounts.
A.8.15	Confirm logging is enabled, time-synchronised, and forwarded to SIEM; verify log retention meets the 180-day minimum.
A.8.16	Trace sampled alerts from generation to analyst triage and closure; confirm triage occurred within defined SLA and closure evidence is retained.
A.5.19	Review vendor risk assessments and confirm security due diligence was performed prior to onboarding and refreshed annually.
A.5.20	Confirm executed contracts contain a security addendum covering data protection, breach notification, right-to-audit, and sub-processor flow-down clauses.
A.5.22	Confirm periodic service review meetings and evidence that material vendor changes (e.g., sub-processor changes) trigger a re-assessment.
A.8.9	Compare live configuration state against the approved CIS-based baseline; confirm deviations are logged and remediated through change control.
A.8.24	Confirm key age against the defined rotation schedule in the Key Management Policy; inspect KMS audit log for rotation events.
A.6.3	Interview HR and IT Security on training delivery; review the training-completion dashboard and most recent phishing-simulation results.
A.8.1	Confirm disk encryption, endpoint detection and response (EDR) agent presence, and patch status on sampled devices.
A.8.3	Attempt role-based query against each sampled data store using a standard (non-privileged) test account; confirm restriction is enforced.

Control ID	Test Procedure
A.5.30	Review the plan for currency (last update, last test date) and observe/inspect evidence of the most recent DR test exercise.
A.8.28	Confirm static application security testing (SAST) is integrated in the CI/CD pipeline and that high/critical findings are tracked to closure.
A.8.23	Confirm filtering policy blocks known malicious-category domains and review proxy logs for evidence of policy enforcement.

Appendix B — List of Documents Reviewed

- Risk Register (v1.0), PaySafe India, dated 2026.
- ISO/IEC 27001:2022 Gap Analysis (v1.0), PaySafe India, dated 2026.
- Access Control Policy (v1.0), PaySafe India, including RBAC matrix, MFA standard, PAM procedure, and offboarding/deprovisioning SLA.
- Identity and Access Management (IAM) platform export — privileged account listing, 42 accounts.
- Active Directory access-certification records, Q2 2026 cycle.
- HR separation records and corresponding IT deprovisioning tickets (ServiceNow export), 18 records.
- SIEM alert queue export, High/Critical severity, audit period.
- Security Operations triage SLA procedure and shift-coverage roster.
- Third-party vendor contract register and sampled executed agreements (credit bureau, card network acquirer, cloud IaaS provider, KYC verification vendor, OTP/SMS gateway).
- Vendor security due-diligence questionnaires and annual review records.
- Key Management System (KMS) audit log and Key Management Policy (v1.0).
- Security-awareness training completion dashboard and Q2 2026 phishing-simulation report.
- Endpoint management console export — disk encryption, EDR agent, and patch status.
- Data store access-control mapping for customer PII and payment-data schemas.
- ICT Business Continuity / Disaster Recovery plan and most recent DR test report.
- CI/CD pipeline configuration and SAST scan results for sampled repositories.
- Web/URL filtering policy configuration and 5-day proxy log sample.
- Configuration Management Database (CMDB) baseline definitions and CIS benchmark mapping.
- Change-control (ITSM) records for the audit period.

Appendix C — Auditee List

The following roles were interviewed and/or provided evidence during fieldwork. Names are withheld from this report and held separately in the audit working papers.

Role	Relevance to Audit
Chief Information Security Officer (CISO)	Audit sponsor; overall ISMS accountability
Head of IT Security	MFA enforcement, SIEM monitoring, PAM oversight
IT Operations Manager	User provisioning/deprovisioning execution
Security Operations (SecOps) Lead	Alert triage, incident monitoring
Head of Compliance	Regulatory obligations (RBI, DPDP Act 2023), policy ownership
Third-Party / Vendor Risk Manager	Supplier due diligence and contract security requirements
Head of Engineering (Infrastructure)	Cryptographic key management, configuration baselines
DevOps Lead	Configuration management, CI/CD, SAST integration
HR Business Partner	Employee separation process, security-awareness training delivery
Data Protection Officer	Customer PII data-store access controls, DPDP Act 2023 alignment

Appendix D — Risk-Based Control Prioritization Rationale

Control selection and testing depth were driven directly by the Risk Register (v1.0) rather than by the Gap Analysis RAG rating alone, to ensure audit effort is concentrated on the controls protecting the organization's highest-risk assets and processes. The rationale is summarized below by underlying asset/process:

Risk Register Asset/Process	Risk Score	Testing Priority	Mapped Controls
Customer PII Stores	25	Highest — Full testing	A.8.24, A.8.3
Payment Processing Systems	20	Highest — Full testing	A.8.9
Admin Access (Privileged Access)	20	Highest — Full testing	A.5.15, A.5.18, A.8.5, A.8.2
Third-Party Integrations	16	High — Full testing	A.5.19, A.5.20, A.5.22
Transaction Database	15	High — Full testing	A.8.15, A.8.16
(Supporting processes — endpoint, BC, code, web filtering, awareness)	6 – 14	Moderate — Targeted/Inquiry	A.8.1, A.5.30, A.8.28, A.8.23, A.6.3

This mapping ensured that no Full-testing effort was allocated to a control protecting an asset scored below 15 on the Risk Register, and conversely that every asset scored 15 or above has at least one control tested to Full depth in this audit.

5. Remediation Tracking Table

All findings in this report are Open as of the report issue date. This table will be maintained by Internal Audit and updated at each remediation checkpoint until all findings are formally closed and validated.

Finding	Severity	Title	Remediation Owner	Target Date	Status
01	Critical	Multi-Factor Authentication Not Consistently Enforced for Privileged and Third-Party Remote Access	Head of IT Security	15 August 2026	Open
02	Critical	Terminated Employee Access Not Deprovisioned Within Required SLA	IT Operations Manager	31 August 2026	Open
03	High	High and Critical Severity SIEM Alerts Not Triaged Within Defined SLA	Head of IT Security	30 September 2026	Open
04	High	Third-Party Lending Data Partner Contract Lacks a Signed Information Security Addendum	Head of Compliance / Third-Party Risk Manager	15 September 2026	Open
05	Medium	Encryption Key Rotation Overdue for Customer PII Data-at-Rest	Head of Engineering (Infrastructure)	31 October 2026	Open
06	Medium	Security Awareness Training Completion and Phishing Resilience Below Target	HR Business Partner / IT Security Manager	30 September 2026	Open
07	Low	Configuration Baseline Drift on Production Payment-Processing Hosts	DevOps Lead	31 October 2026	Open

Internal Audit recommends that the Audit Committee require a formal remediation-status update from the CISO 30 days from report issuance, with independent re-testing of Findings 01 and 02 (Critical) scheduled immediately upon management's declaration of remediation, given their direct relevance to a prior major nonconformity area.

— End of Report —